

Safeguard Compliance Assessment (SCA) Version 1.0 — An Expert System for Determining Compliance with HIPAA Security Rule (HHS RIN 0945-AA22) Notice of Proposed Rulemaking (NPRM).

Thomas P. Dover

ABSTRACT

The Health Insurance Portability and Accountability Act (HIPAA) Security Rule (SR) is the bedrock for determining compliance with federal regulations governing the protection and safeguarding of electronic Protected Health Information (ePHI). Compliance, however, can pose a challenge to Healthcare Delivery Organizations (HDO), large and small, due to the complexity of HIPAA's regulatory framework. This is especially true for Department of Health and Human Services (HHS) proposed changes to the HIPAA Security Rule. Proposed changes consist of 168 distinct Standards and Specifications—as opposed to the current Security Rule's 46 Required or Addressable standards. As proposed, the NPRM represents a far higher level of granularity than the current Rule. To reduce complexity, identify compliance gaps, and provide guidance for correction the NPRM has been distilled to an Expert System using CLIPS¹. The *Safeguard Compliance Assessment (SCA)*² can be employed in standard or technical modes, provides summary statistics, and embeds NIST SP.800-53r5 security controls for mapping identified areas of weakness/vulnerability with industry-recognized security recommendations. Its use is suitable for non-technical or technical audiences (e.g., executive leadership, compliance officers, information security specialists, legal and regulatory counsel) or any healthcare delivery organization subject to HIPAA regulations. A demo version of the SCA Expert System (as proof-of-concept) is available at: <https://github.com/tpd3gmj/HHS-SR-SCA-ES-V1>.

KEYWORDS

Health Insurance Portability and Accountability Act, HIPAA, Electronic Protected Health Information, ePHI, Security Analysis, Security Evaluation, Security Review, Risk Analysis, Risk Assessment, Security Rule, Security Rule Safeguard, APT, HITECH, Healthcare sector, HHS, NIST, NPRM, CLIPS, Expert System, AI Expert System.

¹ C Language Integrated Production System

² Version 1.0

PREFACE

This paper was born out of necessity.

As an Information Security Specialist in the healthcare sector I have watched as my organization's IT environment became increasingly complex and diversified. Because of increased complexity, the single-focus security/risk assessment I had been using was insufficient in its ability to tell me what I need to know; is my organization compliant with HIPAA's Security Rule or not? If not, what are the deficiencies and/or gaps and how do I fix them?

I needed a process or tool for evaluating security and risk that was specific enough to determine compliance with HIPAA³, and to a lesser extent HITECH⁴ and industry best-practices. I also needed an approach that would evaluate (quantitatively and qualitatively) my environment while providing a) an accurate and thorough assessment, b) a useful evaluation for legal and regulatory review, c) recommendations to address deficiencies, and d) an efficient use of time and effort to complete.

But where to start? While requirements for information security—relative to electronic Protected Health Information (ePHI) and imposed by federal law--were readily available I was unable to find a publicly available tool or published approach sufficient enough to evaluate compliance while also simple enough to use without special software or training. While commercial and third-party vendor solutions (i.e., assessments) were available some were cost-prohibitive while others either overly complex or lacked accurate alignment with current Security Rule Safeguards.

Although various security and/or risk assessment frameworks exist such as the International Organization for Standardization (ISO), the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) and others, none align directly with the Security Rule; the direct standard I was attempting to comply with. And with good reason; HIPAA's focus on the protection of ePHI differs from standards more broadly focused on general information security.

In March, 2014, the Department of Health and Human Services (HHS), Office for Civil Rights (OCR) and Office of the National Coordinator for Health Information Technology (ONC) released the Security Risk Assessment (SRA)⁵ tool. As stated on the tool's web page⁶ "The tool is designed to assist small and medium-sized health care practices and business associates in complying with the Health Insurance Portability and Accountability Act (HIPAA) Security Rule." Though useful and aligned with the Security Rule, the SRA is limited as "It is designed to help smaller organizations identify risk and make a plan for remediation and compliance." (HHS-OCR/ONC). Further, the SRA addresses the current Security Rule, not the NPRM. For my purpose, I wanted a process or tool that put my organization's compliance "ahead of the curve".

What I needed was an approach that was not only aligned with both current and proposed Security Rule but was organization-independent meaning that the size and/or complexity of the organization did not matter; extent and degree of HIPAA Safeguard compliance did.

³ Health Insurance Portability and Accountability Act (1996)

⁴ Health Information Technology for Economic and Clinical Health (2009)

⁵ As of version 3.5, the SRA contains 156 questions covering 7 security areas.

⁶ <https://healthit.gov/news/hhs-ocronc-announce-updated-version-its-hipaa-security-risk-assessment-tool/>

While I have been using the SRA (version 3.x) since 2019, on December 27, 2024, HHS issued a Media Release announcing proposed changes to the Security Rule which would “...require updates to existing cybersecurity safeguards to reflect advances in technology and cybersecurity...” The formal Notice of Proposed Rule Making (NPRM) was published in the Federal Register on January 6, 2025.

To remain compliant with proposed changes I initially distilled the NPRM into an Excel workbook. This approach made it relatively easy to differentiate and track between Administrative, Physical and Technical Safeguards but had limitations. For example, the spreadsheet approach did not lend itself easily to non-technical readers and was not practical as a reporting tool for legal review or regulatory audit, or C-suite presentations.

Having developed Expert Systems in the 1990s and 2000s I decided to distill the NPRM into an Expert System format using CLIPS, a public-domain Expert System shell developed in 1985 at NASA Johnson Space Center. The resulting effort is the Safeguard Compliance Assessment (SCA) version 1.0, an Expert System that maps directly to proposed Security Rule changes outlined in the NPRM. The SCA functions by determining Security Rule compliance based on answers to plain-language questions. Unique to the SCA is its incorporation of NIST SP.800-53r5⁷ security control recommendations for areas of weakness or deficiency. Results are provided in both non-technical and technical format thereby providing organizations with reports suitable to both C-Suite/Legal/Regulatory review and Technical Teams tasked with mitigation and ultimately, compliance.

I hope you find it useful.

Thomas P. Dover

© 2026. All Rights Reserved.

tdover@pas-lp.com | tpd_phd@yahoo.com

⁷ National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5).

TABLE OF CONTENTS

ABSTRACT	1
KEYWORDS	1
PREFACE	2
TABLE OF CONTENTS.....	4
1. INTRODUCTION	6
1.1 HIPAA SECURITY RULE.....	6
1.2 HHS RIN 0945-AA22 NPRM.....	7
1.3 THE CHALLENGE OF COMPLIANCE.....	8
2. SAFEGUARD COMPLIANCE ASSESSMENT (SCA) DESIGN	9
2.1 NPRM DISTILLATION	9
2.2 SAFEGUARD COMPLIANCE ASSESSMENT - EXPERT SYSTEM.....	10
3. KNOWLEDGE BASE DESIGN	12
3.1 QDATA FACTS.....	12
3.2 ANSWER CODES	13
3.3 RULE SOURCE CLASSIFICATION	13
3.4 REPORT MODE(S)	14
3.5 OUTPUT MODES	14
3.6 EMERGENT TECHNOLOGIES.....	14
3.7 OPERATIONAL TECHNOLOGY - CONNECTED MEDICAL DEVICES (MIoT)	15
3.8 ARTIFICIAL INTELLIGENCE (AI)	15
4. NIST SP.800-53r5 (CONTROL CATALOG) INTEGRATION	16
5. CLIPS EXPERT SYSTEM	18
5.1 USING CLIPS FOR THE SAFEGUARD COMPLIANCE ASSESSMENT (SCA).....	19
5.2 APPLICATION SECURITY AND FILE INTEGRITY	20
6. OPERATION	21
6.1 RUNNING THE SCA EXPERT SYSTEM	21
7. RESULTS.....	24
8. DISCUSSION.....	27
8.1 OPERATIONAL TECHNOLOGY (OT) - (MEDICAL INTERNET OF THINGS (MIoT)).....	28
8.2 ARTIFICIAL INTELLIGENCE (AI)	29
9. FUTURE WORK.....	30
ACKNOWLEDGEMENTS	31

USE OF GENERATIVE ARTIFICIAL INTELLIGENCE (AI).....	31
DISCLAIMER	31
REFERENCES.....	31

1. INTRODUCTION

The Safeguard Compliance Assessment (SCA) is an Expert System (ES) built using CLIPS (C Language Integrated Production System) Expert System Development Platform.

Using CLIPS, the HIPAA Security Rule (NPRM) has been distilled into an Expert System that maps all proposed changes. The SCA is purposely designed to present questions and provide results in plain language—suitable for non-technical users—while providing an optional “technical” version for IT staff. Through this approach the SCA is suitable to a wide variety of users.

The process and procedure presented in this paper are directed at organizational compliance for the protection of healthcare information designated as electronic *Protected Health Information* (ePHI). Per the Health Insurance Portability and Accountability Act (HIPAA), ePHI requires protection from unauthorized access and/or disclosure.

Security Rule compliance is governed by, and subject to, HIPAA regulations pursuant to United States law.

The following NPRM sections were analyzed for Expert System (ES) development:

- Administrative Safeguards (§164.308)
- Physical Safeguards (§164.310)
- Technical Safeguards (§164.312)
- Organizational Requirements (§164.314)
- Documentation (§164.316)

Sections not evaluated for use by the SCA include §164.103 & 104 (Definitions), §164.106 (General Rules) and §164.320 (Severability). Also not evaluated is §164.318 (Transition Provisions) which has application to the Security Rule but was not incorporated into the SCA due to its focus on timeline transitions post-Final Rule implementation.

1.1 HIPAA SECURITY RULE

The Health Insurance Portability and Accountability Act (HIPAA, 1996) Security Rule (SR) can be considered the bedrock for determining compliance with federal government regulations governing the protection and safeguarding of electronic Protected Health Information (ePHI). Healthcare Delivery Organizations (HDO) are subject to the Security Rule’s requirements for Administrative, Physical and Technical (APT) Safeguards, and must comply with these standards when creating, handling, transmitting or storing ePHI.

A challenge to any organization trying to determine compliance with federal regulations (regardless of critical infrastructure sector) is to first understand those regulations then determine if the organization is compliant and if so, assessing the extent of that compliance.

Originally signed into law in 1996, HIPAA has undergone several updates: 2002 (Privacy Rule), 2009 (HITECH Act), and 2013 (Omnibus Final Rule).

On December 27, 2024, Department of Health and Human Services (HHS)-Office for Civil Rights (OCR) announced its intention to propose an update to HIPAA's Security Rule.

On January 6, 2025, HHS formally published HHS RIN 0945-AA22 NPRM (Notice of Proposed Rule Making) in the Federal Register⁸.

From January 6, 2025 to March 7, 2025 HHS-OCR solicited public comments regarding the proposed changes⁹.

In July, 2026, HHS/OCR published to [reginfo.gov](https://www.reginfo.gov) that Final Action—originally scheduled for July, 2026 has been rescheduled to July, 2027.

1.2 HHS RIN 0945-AA22 NPRM

(HIPAA Security Rule to Strengthen the Cybersecurity of Electronic Protected Health Information)

As stated on Office of Information and Regulatory Affairs, Office of Management and Budget web site¹⁰:

This rule will modify the Security Standards for the Protection of Electronic Protected Health Information (the Security Rule) under the Health Insurance Portability and Accountability Act of 1996 (HIPAA) and the Health Information Technology for Economic and Clinical Health Act of 2009 (HITECH Act). These modifications will improve cybersecurity in the health care sector by strengthening requirements for HIPAA regulated entities to safeguard electronic protected health information to prevent, detect, contain, mitigate, and recover from cybersecurity threats.

The Notice of Proposed Rulemaking (NPRM) can be considered a “superset” of the current Security Rule. It retains current standards but clarifies and/or enhances their implementation. Of special note is that unlike the current Security Rule the NPRM treats all changes as mandatory or “Required”. At present, the current standard allows greater (compliance) flexibility due to “Addressable” versus ‘Required’ standards and specifications. For compliance, the NPRM represents a significant shift away from flexibility to granulation and structure.

In the NPRM's Summary section, HHS explains this tightening of Security Rule compliance as being due, in part, to “common deficiencies the Office for Civil Rights has observed in investigations into Security Rule compliance by covered entities and the business associates...” and “Court decisions that affect enforcement of the Security Rule.” (HHS, 2025)

⁸ <https://www.federalregister.gov/documents/2025/01/06/2024-30983/hipaa-security-rule-to-strengthen-the-cybersecurity-of-electronic-protected-health-information>

⁹ Note: In February, 2025 the College of Healthcare Information Management Executives (CHIME), along with multiple other groups, sent a letter to the federal government recommending that the proposed update be rescinded due, in part, to the heavy financial burden compliance would place on small and medium-sized healthcare providers.

¹⁰ <https://www.reginfo.gov/public/do/eAgendaViewRule?pubId=202510&RIN=0945-AA22>

1.3 THE CHALLENGE OF COMPLIANCE

Though the Security Rule spells out what controls are required relative to HIPAA compliance via Administrative, Physical and Technical means it does not state *how* to accomplish compliance nor does it recommend tools or processes for doing so. This is by design as the Security Rule is structured to allow organizations maximum flexibility for determining the best approach and/or tool for compliance. Given the broad spectrum of Healthcare Delivery Organizations (HDO)—from small, rural practices to large, metropolitan teaching hospitals—applying the same level of *how* and “*with what*” to all healthcare providers may not be the best approach for all.

The Security Rule itself consists of Safeguards (Administrative, Physical, Technical), Standards and Specifications. Standards are baselines for Safeguards and Specifications satisfy Standards. As proposed by the NPRM, an organization must address each Safeguard’s Specification and Standard.

For HDOs large and small, Security Rule compliance may fall upon staff inexperienced with Security Rule Safeguards and their attendant Standards and Specifications. In addition, significant time and effort must be undertaken to first understand SR requirements then take steps to comply with them.

Security Rule Administrative Safeguard, section 1(A) mandates that HDOs “conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the Confidentiality, Integrity and Availability (CIA) of electronic protected health information...” (LII Legal Information Institute, n.d.)

Current approaches to Security Rule assessment include SOC¹¹ audits and HITRUST certification, however, neither perfectly aligns with current (or proposed) HIPAA Safeguards. SOC or HITRUST certification can be considered indicators of strong cybersecurity practice(s) but are not, in and of themselves, qualified indicators of HIPAA Security Rule compliance.

Unique to the SCA is that its questions are mapped directly from the NPRM, therefore, its standards and specifications match what is being proposed without adding any additional security measures or omitting existing ones. Unlike assessments that result in lengthy narratives¹² the SCA is precise in design, straightforward in use and clear in results.

To date, there is no publicly available assessment/compliance tool built directly from the NPRM. The SCA is designed specifically for assessing proposed changes to the Security Rule but which also contains filtering for the current Security Rule.

¹¹ AICPA SOC-2, Type II certification

¹² This observation is based, in part, on the author’s decade-long experience of reviewing HIPAA compliance assessment summaries produced by commercial service providers.

2. SAFEGUARD COMPLIANCE ASSESSMENT (SCA) DESIGN

2.1 NPRM DISTILLATION

The NPRM has been analyzed and distilled into 168 questions covering five Safeguards (3 “core” + 2 additional Safeguards)¹³. The Administrative Safeguard contains the most standards (15) and specifications (77) which point to a strong emphasis on Governance, Risk Management and Compliance (GRC). By contrast, Physical Safeguard has only 4 standards and 13 specifications. Note: the number of questions is based on analysis of NPRM Standards and Specifications, not an official (HHS) summary. The NPRM itself does not enumerate specific questions.

The NPRM is organized into the following sections:

- Definitions (§164.103)
- Definitions (§164.304)
- Security Standards: General Rules (§164.106)
- Administrative Safeguards (§164.308)*
- Physical Safeguards (§164.310)*
- Technical Safeguards (§164.312)*
- Organizational Requirements (§164.314)*
- Documentation (§164.316)*
- Transition Provisions (§164.318)
- Severability (§164.320)

*-incorporated into SCA

It also includes sections covering *New and Emerging Technologies Request for Information*¹⁴ and *Regulatory Impact Analysis* [Exec. Order No. 12866, 1994; Exec. Order No. 13132, 2000].

It should be noted that Section 164.318 (Transition Provisions) was not included in the Expert System. This section deals with “compliance timeline” for regulated entities once the Final Rule is published. It does not establish new Safeguards, Standards or Specifications, therefore its inclusion as a metric for compliance with the Security Rule itself is unnecessary.

¹³ Review identified approximately 50-60 specific regulatory changes to the Security Rule

¹⁴ Quantum Computing, Artificial Intelligence (AI) and Virtual and Augmented Reality (VR and AR)

Each Safeguard contains Standards and Specifications. For example:

Safeguard: ADMINISTRATIVE

Standard: Technology Asset Inventory

Specification: Network Map

Specification provides the compliance requirement used by the Expert System. For example, *Network Map* specification is:

Develop a network map that illustrates the movement of electronic protected health information throughout the covered entity's or business associate's electronic information systems, including but not limited to how electronic protected health information enters and exits such information systems, and is accessed from outside of such information systems.

While relatively straightforward, not all specifications are structured this way. Some also contain specific citation references. For example:

Safeguard: ADMINISTRATIVE

Standard: Technology Asset Inventory

Specification: Maintenance

Review and update the written inventory of technology assets required by paragraph (a)(1)(ii)(A) of this section and the network map required by paragraph (a)(1)(ii)(B) of this section in the following circumstances...

Though accurate and concise the regulatory structure of the specification may present a challenge to those unfamiliar with regulatory citation. Therefore, questions posed by the SCA retain their NPRM structure and meaning but use plain language for presentation.

For example, the SCA presents the above Standard and Specification as:

On an ongoing basis, but at least once every 12 months, does your organization review and update your written 'Technology Asset Inventory' including a network map?

2.2 SAFEGUARD COMPLIANCE ASSESSMENT - EXPERT SYSTEM

Whereas the current Security Rule contains 46 Standards and Implementation Specifications--26 Required and 20 Addressable (HHS, 2013)--the NPRM (HHS, 2025) contains 168 such conditions which are not only required but are much more granular in their specification than the current Security Rule.

Since the Security Rule, in general, can be considered a static document with infrequent changes it maps well to Expert System architecture & design. By definition, an Expert System is "a computer system emulating the decision-making ability of a human expert." (Jackson, 1998)

As stated earlier, the SCA is an Expert System intended for a wide variety of users. NPRM requirements are presented in straightforward, everyday language with compliance ranging from fully-to-partial-to-non-compliant. Users can select either technical or non-technical output formatted in either plain text or .html formats. HTML formats can then be “printed” in .pdf format providing a complete, easy-to-read report suitable to most business needs and/or legal and regulatory requirements.

The SCA saves session answers in a simple “answer key” text file which can be optionally loaded at the start of the program. This allows the user to either begin a new assessment or review—and edit if needed—a previously completed assessment. See the installation and configuration guide for details.

Since the SCA contains 168 total questions covering Administrative, Physical and Technical (APT) safeguards, each Safeguard is broken down into separate Expert System .clp¹⁵ modules for ease-of-use and management. The SCA also contains an Organizational Requirements module (11 questions) and Policies & Documentation module (3 questions). These sections are also Security Rule Safeguards and their inclusion in the SCA is essential for overall continuity of the assessment.

The remainder of this paper describes the design of the Expert System as well as the Knowledge Base it supports. It further outlines the benefit of using the SCA for compliance as well as future work.

Demo version of the SCA Expert System is distributed as self-contained CLIPS (.clp) files and are available for download from: <https://github.com/tpd3gmj/HHS-SR-SCA-ES-V1>. The repository includes proof-of-concept demo versions for three (of five) Security Rule Safeguards (Administrative, Physical & Technical). Also available is the Installation and Configuration Guide, file integrity (hash) verification file, and the CLIPS 6.x installer obtained from the official SourceForge repository at <https://sourceforge.net/projects/clipsrules/files/CLIPS/>.

¹⁵ CLIPS extension

3. KNOWLEDGE BASE DESIGN

The SCA Knowledge Base (KB) contains the facts, rules, and conditions used by the Expert System. It is updated as new or changed information relative to the Security Rule is published.

The KB contains 26 distinct fields which are grouped by purpose (Table 1). All fields are ordered as “qdata” facts which are initialized into working memory during system startup.

Table 1. Knowledge Base framework

GROUP	FIELD	PURPOSE
Control ID	Control_id, standard, etc.	Unique ID and regulatory mapping
Assessment	Question, valid answers, etc.	Question and response
Scoring	Weight, etc.	Scoring parameters
Findings	Compliant, partial, etc.	Context-specific
Remediation	Reference name, control, etc.	NIST SP.800-53r5 reference
NIST Reference	Name, control, section, etc.	Specific Control catalog guidance
Regulatory Classification	SR, NPRM, etc.	State of regulation (current SR v. NPRM)

3.1 QDATA FACTS

Knowledgebase fields are defined as ‘qdata’ ordered facts. They are inserted into working memory at startup via *deffacts question-data* construct.

Each fact contains 26 positional fields accessed using CLIPS *nth\$* function. For example, *nth\$ 1* retrieves the sequence number, *nth\$ 4* the (Security Rule) Standard name and *nth\$ 5* the Question text.

During assessment, the *ask-next-question* rule matches the current question number against field 1 (sequence number). During report generation, a *do-for-fact* lookup matches the response against control_id and retrieves NIST reference and other information based on the answered question.

This architecture makes each CLIPS (.clp) file self-contained with no dependencies required at runtime and with the knowledge base embedded directly into the .clp file.

3.2 ANSWER CODES

Answer codes and their numeric values determine degree of compliance (Table 2).

Table 2. Supported Answer codes

ANSWER CODE	WEIGHT
(Y)es	1
(N)o	0
(P)artial	0.5
Does Not Apply (DNA)	1
Alternate Option/Process (ALT)	1
(U)ncertain	0

Note: for statistical purposes answer codes **DNA** & **ALT** are assigned a value of 1 (compliance).

3.3 RULE SOURCE CLASSIFICATION

Due to HHS decision to delay Final Rule publication until July, 2027 a “Rule Source” field (with attendant definition) was added to the knowledge base. Its purpose is to distinguish between standards/specifications currently in the Security Rule—with further refinement between Required and Addressable standards—and those proposed by the NPRM. Rule source definitions are listed in Table 3.

Table 3. Rule Source & Definition

RULE SOURCE	DEFINITION
SR-R	A REQUIRED standard in the current Security Rule
SR-A	An ADDRESSABLE standard in the current Security Rule
SR-RE	A REQUIRED standard in the current Security Rule but enhanced by the NPRM
SR-AE	An ADDRESSABLE standard in the current Security Rule but enhanced by the NPRM
NPRM	A new standard proposed by the NPRM

The SCA outputs the Rule Source field in all report formats and in both Answer Key table (FIG 1) and individual Standard/Specification results (FIG 2).

ANSWER KEY				
Control	Ans	Score	Finding	Rule Source
ADM-01	Y	1.0	Compliant	NPRM
ADM-02	N	0.0	Non-compliant	NPRM
ADM-03	Y	1.0	Compliant	NPRM
ADM-04	Y	1.0	Compliant	NPRM
ADM-05	N	0.0	Non-compliant	SR-RE
ADM-06	Y	1.0	Compliant	SR-RE
ADM-07	Y	1.0	Compliant	SR-RE
ADM-08	Y	1.0	Compliant	SR-RE

Figure 1

3.4 REPORT MODE(S)

- **Standard:** plain language without NIST references (FIG 2)
- **Technical:** plain language including NIST references

3.5 OUTPUT MODES

- **Text** – plain text (.txt) (useful for importing into other formats or applications)
- **HTML** – browser (.html) (can be “printed” in .pdf format)
- **Screen Only** – Screen (useful for screen image captures)

```
=====
COMPLIANT
=====

[ADM-01]
Standard: TECHNOLOGY ASSET INVENTORY
Specification: 164.308 (ii) (A) [Inventory]
Rule Source: A new standard proposed by the NPRM
Question: Has your organization developed a written inventory of your technology
assets that contains the identification, version, person accountable, and
location of each technology asset?
Answer: Y | Finding: Compliant
```

Figure 2 (example of HTML Output)

For reporting, the Rule Source field uses plain language for readability.

Note: Depending on the Standards/Specifications contained in the Final Rule the ‘Rule Source’ field may be revised or removed from both the Knowledge Base and all reporting formats.

By distinguishing between current, current but enhanced, and newly proposed standards, users will be able to differentiate between current cybersecurity needs and those suitable for future planning due to anticipated requirement.

3.6 EMERGENT TECHNOLOGIES

Emergent technologies are those that have been developed since implementation of the Security Rule in 2003. Two such technologies having the greatest impact on healthcare delivery are Operational Technology (MIoT) and Artificial Intelligence (AI). Although not explicitly stated in the NPRM, Operational Technology and Artificial Intelligence are referenced in SCA questions.

3.7 OPERATIONAL TECHNOLOGY - CONNECTED MEDICAL DEVICES (MIoT)

Table 4 depicts Expert System questions associated with Medical Internet of Things.

Table 4. SCA questions associated with the use of MIoT

Question	Standard	Description
ADM 01-04	Technology Asset Inventory	Devices must be inventoried and mapped
ADM 16-26	Patch Management	FDA Regulatory constraint and exception framework
ADM 52, TECH-06	Network Segmentation	Covers networked medical devices
TECH 09-20	Encryption MIoT Exception (FDA)	MIoT devices not supported by encryption, compensating controls, administrative management & review, Documentation
TECH 34-44	Multi-Factor Authentication (MFA)	MFA requirements, MIoT exceptions, administrative review

3.8 ARTIFICIAL INTELLIGENCE (AI)

Table 5 lists 13 implied questions which can be associated with the use of AI.

Table 5. Implied AI standards/specifications

Question	Standard	Description
ADM 01-13	Technology Asset Inventory & Risk Analysis	AI implicitly addressed through Technology Assets and Risk Analysis.

4. NIST SP.800-53r5 (CONTROL CATALOG) INTEGRATION

NIST SP.800-53r5 is considered by many in the information security field as the essential source for security and privacy controls. Within its 492 pages there are twenty (20) distinct control families and over 1,000 security and privacy controls.

The SCA takes advantage of this “deep well” by integrating NIST SP.800-53r5 with each question asked by the Expert System. If the “technical” version of SCA reporting is selected then the Control Catalog’s Control Family, Section, and page number(s) are provided in report output. This provides an organization with established and authoritative guidance when evaluating appropriate cybersecurity controls for its environment.

As will be seen in the Results chapter, having NIST guidance in-hand saves time for organizations seeking third-party assistance with achieving Security Rule compliance.

For example, figure 3 depicts a Control Catalog citation:

PS-8 PERSONNEL SANCTIONS	
<u>Control:</u>	
a. Employ a formal sanctions process for individuals failing to comply with established information security and privacy policies and procedures; and	
b. Notify [<i>Assignment: organization-defined personnel or roles</i>] within [<i>Assignment: organization-defined time period</i>] when a formal employee sanctions process is initiated, identifying the individual sanctioned and the reason for the sanction.	
<u>Discussion:</u> Organizational sanctions reflect applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Sanctions processes are described in access agreements and can be included as part of general personnel policies for organizations and/or specified in security and privacy policies. Organizations consult with the Office of the General Counsel regarding matters of employee sanctions.	
CHAPTER THREE	PAGE 227
NIST SP 800-53, Rev. 5	SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS
<u>Related Controls:</u> All XX-1 Controls, PL-4 , PM-12 , PS-6 , PT-1 .	
<u>Control Enhancements:</u> None.	
<u>References:</u> None.	

Figure 3

Assuming a Safeguard standard/specification that is either not or only partially met, the Control's text could be used in a web search for open-source or commercial solutions which would satisfy the requirement. This approach not only provides an efficient method for obtaining an appropriate solution it also creates an aligned path between the Security Rule Safeguard and established-recommended Best Practice(s) that the NIST Control Catalog offers.

Another advantage of using NIST SP.800-53r5 for Safeguard compliance is that its inherent authority aids organizations with justifying and, if needed, defending a particular approach or technology in response to legal queries and/or regulatory audits.

5. CLIPS EXPERT SYSTEM

As stated earlier the NPRM was initially distilled into an Excel workbook. While relatively easy to use, a dedicated spreadsheet has limitations.

Since the Security Rule, in general, can be considered a static document with infrequent changes it maps well to Expert System (ES) technology. By definition, an Expert System is “a computer system emulating the decision-making ability of a human expert.” (Jackson, 1998)

An Expert System consists of the following components:

- Knowledge Base (contains facts, rules and other information necessary to solve problems)
- Inference Engine (a processor for reasoning)
- User Interface (interactive component for input into the ES)

CLIPS is a public-domain Expert System developed by the Software Technology Branch (STB)/ NASA Johnson Space Center in 1985 and released in 1986¹⁶ (FIG 3). It is a tool¹⁷ for complete development and execution of an ES and can run either as a standalone application or in a server environment. The current iteration of CLIPS is designed and maintained by Gary Riley.

CLIPS is “forward-chaining”¹⁸ where data entered into the system is evaluated by rule conditions which then assert new facts. In effect, known data (i.e., answer to a question) is logically evaluated to produce new information.

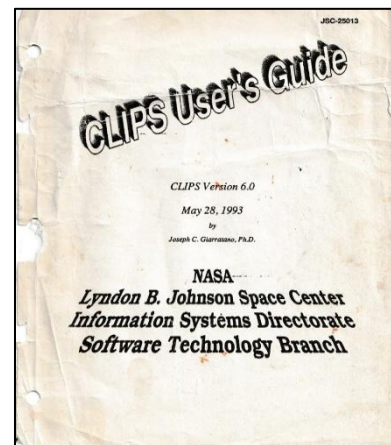


Figure 3

¹⁶ Current version of CLIPS is 6.4.2, released in January, 2025.

¹⁷ CLIPS is called a 'tool' because "it is a complete environment for developing expert systems which includes features such as an integrated editor and debugger". Joseph C. Giarratano, Ph.D., *CLIPS User's Guide* (NASA Johnson Space Center, Information Systems Directorate, Software Technology Branch, 1993) 1.

¹⁸ Forward-chaining ES uses a deductive approach to logical inference. That is, start with a set of facts and deduce an answer or new facts.

5.1 USING CLIPS FOR THE SAFEGUARD COMPLIANCE ASSESSMENT (SCA)

The question can reasonably be asked why use an Expert System for Security Rule compliance instead of Generative AI¹⁹? While GenAI systems are dynamic, unstructured and flexible their results can be subject to change as new information is introduced.

By contrast, Expert Systems--among the first successful applications of AI--are well-suited for narrowly defined knowledge domains that do not change frequently. In the case of the Security Rule, change is infrequent which makes the results of an Expert System built upon it predictable (logical following), explainable (decision-making) and stable (they do not create new information but remain within the confines of known facts and the rules governing those facts).

Although the NPRM remains in a *proposed* state, its Standards and Specifications are clearly defined. This makes using the SCA optimal since its presentation to the user is in plain language; its results are actionable, and its documentation supports legal and/or regulatory scrutiny.

Another advantage of using CLIPS is that unlike contemporary applications which may run from either an application server or the Cloud CLIPS is modular (i.e., standalone) and can be run from any Windows-based workstation (no internet or network needed). Its only run-time dependencies are those native to the program itself (FIG.4). Of note is that CLIPS contains both Windows and DOS²⁰ interfaces.

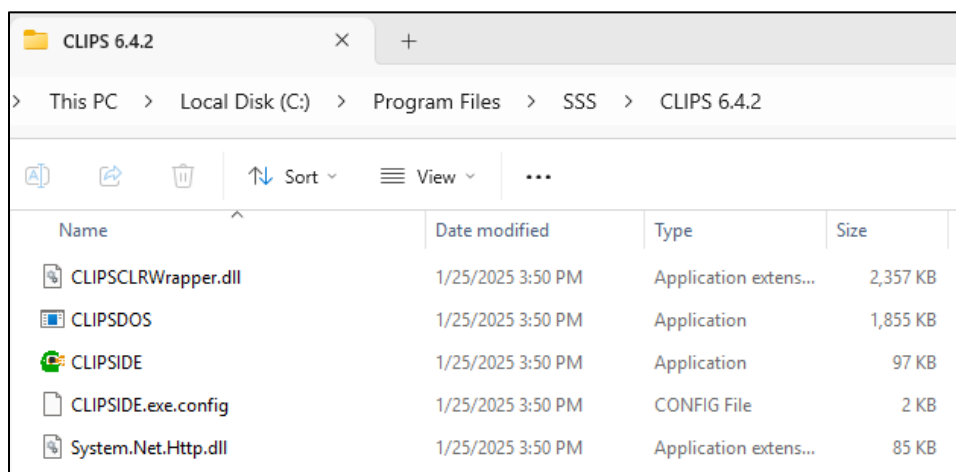


Figure 4

¹⁹ Examples of Generative AI (GenAI) systems include Large Language Models (LLM) such as Microsoft *Copilot*, Anthropic *Claude*, OpenAI *ChatGPT*, Google *Gemini* and others.

²⁰ Disk Operating System (DOS)

5.2 APPLICATION SECURITY AND FILE INTEGRITY

CLIPS has a relatively limited (malware) attack surface when run as a standalone application. It can, however, be exposed to risk from the workstation where it is run.

As CLIPS is a standalone, single-threaded, text-based inference engine, its protections include:

- Can run entirely on a standalone workstation
- No network or internet connection needed
- No remote procedure calls or API surface
- Reads/Writes only to local files
- No database or web connection(s)
- Is not a service or daemon—it runs only when invoked by a user

As stated above, an infected or compromised workstation could pose risk to a user running the CLIPS Expert System since .CLP files are plain text files which could be manipulated by an attacker. This exposure, however, is only present if a user runs an untrusted .CLP file or does not check for file integrity which is accomplished via cryptographic hashing²¹.

²¹ Hashing is a one-way mathematical function that converts data to a unique, fixed-length value. A hashed value changes if any change is made to the underlying data (e.g., file).

6. OPERATION

6.1 RUNNING THE SCA EXPERT SYSTEM

Workflow of the SCA is:

Banner → Asking → Reporting → Revising/Editing → Done

Using the Safeguard Compliance Assessment Expert System is straightforward and consists of the following steps:

1. Start CLIPS
2. Load Security Rule Safeguard CLIPS file (.clp)
3. Load Answer File (optional)
4. Select Report Mode (Standard or Technical)
5. Select Output Mode (Text, HTML, Screen Only)
6. Complete Assessment.

Upon startup, the user is presented with an opening banner (FIG 5):

```
CLIPS IDE
File Edit Environment Debug Help
Dir: C:\CLIPSprograms\HHSSR

CLIPS (6.4.2 1/14/25)
CLIPS> (load "HHS-SRA-164.308-Administrative.clp")
%%$!$!!!!!!!!!!!!!!!!!!!!*****
TRUE
CLIPS> (reset)
CLIPS> (run)

=====
HIPAA Security Rule - Safeguard Compliance Assessment (SCA)
Expert System (ES) (v1.0)
Administrative Safeguards | Controls ADM-01 to ADM-83
45 CFR Part 164 Security Rule | HHS RIN 0945-AA22 NPRM
-----

Copyright 2026. Thomas P. Dover. All Rights Reserved.
Contact: tdover@pas-lp.com | tpd_phd@yahoo.com
=====

ABOUT ADMINISTRATIVE SAFEGUARDS
=====
Each 'Covered Entity' (Healthcare Delivery Organization) and
'Business Associate' (Contractor, Vendor, 3rd Party) must, in
accordance with §§ 164.306 (General Rules) and 164.316
(Policies, Procedures, and Documentation Requirements),
implement safeguards to protect the confidentiality,
integrity, and availability of all electronic protected health
information that it creates, receives, maintains, or
transmits.
=====

Answer codes:
Y = Yes (fully implemented)
N = No (not implemented)
P = Partial (partially implemented)
DNA = Does Not Apply
ALT = Alternative measure in place
U = Unknown

Scoring: Y/ALT/DNA = 1.0 | P = 0.5 | N/U = 0.0

NOTE: Findings and Recommendations are presented in the
End-of-Assessment Report after all questions are answered.

-----
REPORT MODE
-----
1 = Standard (plain language guidance)
2 = Technical (plain language + NIST control references)

Enter selection (1 or 2): |
```

Figure 5

Information about the Security Rule Safeguard, Answer Codes and Scoring are presented in the opening banner.

The user is first prompted to select the “Report Mode”. Options are *Standard* (plain language without technical reference) or *Technical*.

The user is then asked to select the “Output Mode”. Options are *Screen Only*, *Text* or *HTML*. Text-based reports can be imported into any program or application that accepts and/or can parse plain text. HTML reports can be converted to Adobe .pdf format through standard print-to function.

Both Report and Output mode are required and the program will not continue until these options are selected.

The user is then prompted to enter organizational information including Date (of assessment), Completed By, Title and Organization. This information is optional, however, and can be left blank.

Next, the user is asked where (path) to store results. File paths are optional and can be pre-defined, however, CLIPS saves results to the default CLIPS directory if no path is entered.

Finally, CLIPS will prompt the user to enter the path for the “answers.txt” file. As with the results file, the path can be either pre-defined or default. Note: the first time a .clp file is run it creates an initial answers.txt file. Only during subsequent sessions will CLIPS advise that it has found answers.txt and will prompt the user if they want to use this file.

Once Report and Output modes have been selected and organizational information provided the user is presented with questions aligned to NPRM Standards and Specifications (FIG 6):

[ADM-02] Technology Asset Inventory | CFR: 164.308 (ii)(B) [Network Map]

Q2: Has your organization developed a network map that illustrates the movement of electronic protected health information throughout your electronic information systems, including but not limited to, how electronic protected health enters and exits such information systems, and is accessed from outside of such information systems?

Enter answer (Y / N / P / DNA / ALT / U): |

Figure 6

In addition to the question itself, reference information including Standard, CFR²² citation and Specification [e.g., Network Map] is provided.

The Expert System cycles through its list of questions and records each response. Once complete, the system produces the output report based on report type and output mode entered earlier.

²² Code of Federal Regulations (CFR)

7. RESULTS

Report information includes sections covering Compliant, Partial Compliance, Non-Compliant and Non-Applicable specifications. Each compliance level is color-coded for readability. It should be noted that compliant specifications do not provide NIST Control Catalog technical reference as they are considered “satisfied” by the answer code (Figure 7).

```
=====
COMPLIANT
=====

[ADM-01]
Standard: TECHNOLOGY ASSET INVENTORY
Specification: 164.308 (ii)(A) [Inventory]
Rule Source: A new standard proposed by the NPRM
Question: Has your organization developed a written inventory of your technology
assets that contains the identification, version, person accountable, and
location of each technology asset?
Answer: Y | Finding: Compliant
```

Figure 7 (Output showing Finding=Compliant)

By contrast, Partial and Non-Compliant results provide Guidance and Technical reference to NIST (Control Catalog) family providing Section and Page reference (FIGS 8-10). **Note:** vertical bar color-coding is added for readability.

```
[ADM-32]
Standard: SANCTION POLICY
Specification: 164.308 (ii)(B) [Modifications]
Rule Source: A REQUIRED standard in the current Security Rule but enhanced by the
NPRM
Question: Does your organization review written sanctions policies and procedures
at least once every 12 months, and modify them as reasonable and appropriate?
Answer: P | Finding: Partial Compliance

Guidance: Establish a documented annual review cycle for your sanction
policies. Record results of each review and document any updates made.

Technical: Formalize annual review of sanction policies per PS-8. Update
policies to reflect changes in workforce roles, security requirements, or
organizational structure per PL-4.

Reference: NIST SP 800-53r5 | Personnel Security (PS), Planning (PL) | Sections: PS-
8, PL-4 | Pages: 231, 191
```

Figure 8 (Partial Compliance)

=====

NON-COMPLIANT AND PARTIAL COMPLIANCE | RECOMMENDATIONS AND GUIDANCE

=====

[ADM-02]

Standard: TECHNOLOGY ASSET INVENTORY

Specification: 164.308 (ii)(B) [Network Map]

Rule Source: A new standard proposed by the NPRM

Question: Has your organization developed a network map that illustrates the movement of electronic protected health information throughout your electronic information systems, including but not limited to, how electronic protected health enters and exits such information systems, and is accessed from outside of such information systems?

Answer: N | **Finding:** Non-compliant

Guidance: Create a written network map showing how ePHI moves through all your electronic information systems. Include all systems, connections, and data flows. Assign an owner and keep it current.

Technical: Develop a network map per CM-12 that illustrates all ePHI movement across relevant electronic information systems. Align with system component inventory per CM-8 and system security plan per PL-8.

Reference: NIST SP 800-53r5 | Configuration Management (CM) | Sections: CM-8, CM-12, PL-8 | Pages: 107, 112, 193

Figure 9 (Non-Compliant)

[ADM-48]

Standard: INFORMATION ACCESS MANAGEMENT

Specification: 164.308 (ii)(A) [Isolated Health Care Clearinghouse Functions]

Rule Source: A REQUIRED standard in the current Security Rule

Question: If a health care clearinghouse is part of your organization has it established and implemented written policies and procedures that protect the electronic protected health information and relevant electronic information systems of the clearinghouse from unauthorized access by the larger organization?

Answer: DNA | **Finding:** Does Not Apply

Figure 10 (Not Applicable)

SCA report results also include summary statistics (FIG 11):

=====
RESULTS
=====
=====
HIPAA SRA ASSESSMENT REPORT
Administrative Safeguards ADM-01 to ADM-83
=====

STATISTICS

TOTAL SCORE : 75.5 / 83.0
PERCENTAGE : 90.96%
Compliant : 72
Partial : 3
Non-compliant : 6
Does Not Apply : 2 (scored as compliant)

Figure 11

8. DISCUSSION

Too often, healthcare providers subject to the HIPAA Security Rule possess only one side of the compliance “equation”. Either organizations know where compliance is insufficient but are unsure how to address weakness, vulnerability or risk; or have a protective technology in place but are unsure to which Security Rule Safeguard the technology applies. As a result, an accurate determination of how compliant an organization is can be difficult to (accurately) assess. Such assessment, however, is critical for optimal planning of cost, time and effort.

Unfortunately, the current Security Rule itself adds to this challenge as some Safeguard standards are generalized with some being ‘Required’ and others ‘Addressable’.

The Safeguard Compliance Assessment represents an initial attempt at providing healthcare delivery organizations, regardless of size, a method for evaluating compliance with Security Rule changes proposed by the NPRM. Since the SCA is a superset of the current Security Rule it can also be used to determine compliance with current Rule standards and specifications.

In effect, the SCA addresses both sides of the ‘equation’; it identifies weakness and/or deficiencies and provides industry-standard guidance for correction via an integrated approach.

As stated, the Expert System is fully backward-compatible with the current Security Rule. Given the rescheduling of the Final Rule until July, 2027 the *rule_source* field has been added to distinguish between current Security Rule requirements and those proposed in the NPRM.

As the safekeeping of an organization’s security posture is paramount to its operations a significant advantage for using the SCA is that it serves as a standalone offline tool. It requires neither network connection nor internet access. Results are stored locally without the possibility of transmission to external servers, the Cloud or third-parties.

The use of the Safeguard Compliance Assessment, built upon the CLIPS Expert System, represents a unique integration of proposed HHS NPRM (RIN 0945-AA22) Standards and Specifications, and NIST SP.800-53r5 (Security Control Catalog) thus satisfying the compliance requirements of identification of *problem* (gaps or weaknesses) and *solution* (industry-standard best practices).

The NPRM, contrasted against the current Security Rule, is much more granular, explicitly stating that ALL Safeguard standards and specifications are required. The shift from generality to specificity has been a trend in cybersecurity and information protection for the past several years. Examples of increased granulation include NIST SP.800-171r3²³ and its companion NIST SP.800-172²⁴, and DoD CMMC²⁵.

²³ NIST SP.800-171r3. *Protecting Uncontrolled Unclassified Information in Nonfederal Systems and Organizations*. 2024. National Institute of Standards and Technology. Available from: <https://csrc.nist.gov/pubs/sp/800/171/r3/final>

²⁴ NIST SP.800-172. *Enhanced Security Requirements for Protecting Uncontrolled Unclassified Information: A supplement to NIST Special Publication 800-171*. 2021. National Institute of Standards and Technology. Available from: <https://csrc.nist.gov/pubs/sp/800/172/final>

²⁵ Department of Defense (DoD), Cybersecurity Maturity Model Certification (CMMC)

The SCA also addresses two emergent technologies not covered in the current Security Rule; Operational Technology (aka Internet of Things (IoT) or Medical Internet of Things (MIoT)), and Artificial Intelligence (i.e., generative or agentic AI).

Despite its usefulness, the SCA is limited by its reliance on Final Rule publication although changes are readily addressed through the underlying knowledge base. Further, it is limited in its ability to evaluate compliance (full, partial, none) without attestation (of compliance). These limitations, however, have been addressed in version 2.0 wherein *Satisfying Statement* and *Validation Tool/Process* fields were added to provide structured documentation in support of compliance.

It should be noted that the SCA does not utilize §164.318 (Transition Provisions) as this section addresses requirements post-Final Rule publication.

Finally, the SCA Expert System has many business-case uses including, but not limited to:

- Due Diligence (Mergers & Acquisitions)
- Insurance Review
- Legal and/or Regulatory Review
- Organizational Cybersecurity Review & Enhancement
- Risk Management
- SOC-2, Type II Audit (organizational assertion)
- Planning (Cost|Staff|Resources)

8.1 OPERATIONAL TECHNOLOGY (OT) - (MEDICAL INTERNET OF THINGS (MIoT))

Medical devices capable of network connectivity and internet communication have been in existence for approximately 10-15 years. Examples include fitness trackers, heart monitors and glucose sensors. While such devices are regulated by the Food and Drug Administration (FDA)--not HHS--their use constitutes a cybersecurity risk due to their ability to collect, analyze, store and transmit sensitive or protected health information.

The current Security Rule does not specifically refer to either “operational technology” or “MIoT” since it did not exist at time of Rule implementation in 2003. It does, however, reference “medical devices”, “medical equipment” and “networked medical devices”.

The NPRM references OT in its preamble stating that medical devices are targets and that cybercriminals target such devices used for healthcare. Further, OT is referenced in the following Safeguards/Standards/Specifications:

Administrative Safeguard:

- **Technology Asset Inventory**²⁶ - Inventory of assets including medical devices and networked medical equipment
- **Patch Management**²⁷ FDA (non) review of software patches or configuration updates. Basis for FDA exception of devices that cannot be patched due to manufacturer reason or FDA constraint.

Technical Safeguard:

- **Authentication**²⁸ - Mandatory use of Multi-Factor Authentication (MFA) with exception for medical devices that do not support MFA
- **Access Control**²⁹ - Network segmentation requirement as a means for preventing pass-thru attacks
- **Encryption and Decryption**³⁰ - Mandatory use of encryption with exception for medical devices that do not support encryption

Note: the Expert System employs the term “MIoT” interchangeably with ‘medical devices’, ‘medical equipment’ and ‘networked medical devices’ for readability. SCA Safeguard (Technology) questions TECH-13, 14, 15, 18, 38, 39, 40, 41, 42 and 43 reference “MIoT”.

8.2 ARTIFICIAL INTELLIGENCE (AI)

Artificial Intelligence or AI is not explicitly referenced anywhere in the NPRM although indirect reference can be made through the following text “... regulated entities must be prepared to identify, mitigate, and remediate such risks and vulnerabilities” (U.S. Department of Health and Human Services (HHS), 2025). The NPRM also references White House Executive Order 14110 which calls for HHS to establish an AI Task Force.

The NPRM also makes a Request-for-Information (RFI) stating “New and Emerging Technologies Request for Information: Artificial Intelligence (AI)” (*Health Insurance Portability and Accountability Act Security Rule*, 2025) although the RFI is not presented as a Safeguard Standard or Specification.

AI compliance requirements can be inferred from the same Safeguards, Standards and Specifications as Operational Technology with the addition of Risk Analysis³¹ where risks imposed by the use of AI must be assessed. AI requirements, however, are inferred only and are not explicit to NPRM requirements.

²⁶ §164.308(a)(1)(i)

²⁷ §164.308(a)(4)(i)

²⁸ §164.312(f)(1)

²⁹ §164.312(a)(1)

³⁰ §164.312(b)(2)

³¹ §164.308(a)(2)(i)

9. FUTURE WORK

The SCA v1.0 is an Expert System tool for identifying gaps and weaknesses with HIPAA Security Rule compliance (both current and NPRM).

Despite its benefits two distinct fields have been purposely left out of the SCA; *Satisfying Statement* and *Validation Tool/Process*.

Satisfying Statement is a short (1-2 sentence) statement describing who is responsible for, or how a particular Safeguard/Standard/Specification is met. For example:

Safeguard: Administrative

Standard: Technology Asset Inventory

Specification: Develop a written inventory of the covered entity's or business associate's technology assets that contains the identification, version, person accountable, and location of each technology asset.

Satisfying Statement: *Asset inventory is maintained by IT Support Team. See Equipment and Management Policy and Procedures.*

The Satisfying Statement avoids lengthy narratives while providing clear, concise and verifiable description how the Standard/Specification is met.

Validation Tool/Process identifies the specific tool(s) and/or processes used to satisfy the specification. For example:

Safeguard: Administrative

Standard: Technology Asset Inventory

Specification: Develop a written inventory of the covered entity's or business associate's technology assets that contains the identification, version, person accountable, and location of each technology asset.

Validation Tool/Process: *ABC Asset Management application or service.*

Both *Satisfying Statement* and *Validation Tool/Process* were purposely omitted from SCA version 1.0 in order to minimize the length of time, effort and detail required to complete any given Safeguard Expert System module.

Both fields were subsequently added to Safeguard Compliance Assessment, version 2.0.

Pending issuance of the Final (Security) Rule by HHS, currently scheduled July, 2027, the SCA Knowledge Base will be revised to accommodate applicable changes. This action will align the SCA with the newly published Security Rule without the need for complete re-creation of the entire Expert System.

ACKNOWLEDGEMENTS

The author would like to thank Mr. Gary Riley for his continued development and maintenance of CLIPS, the Expert System upon which the Safeguard Compliance Assessment is built.

The author would also like to acknowledge the U.S. Department of Health and Human Services, Office for Civil Rights, for its publication of HHS RIN 0945-AA22, the Notice of Proposed Rulemaking. It is this document that forms the foundation of the Safeguard Compliance Assessment.

USE OF GENERATIVE ARTIFICIAL INTELLIGENCE (AI)

Generative AI was used in the following aspects of this project:

1. Research & Analysis
2. Knowledgebase Configuration
3. CLIPS code review and debugging
4. CLIPS Installation and Configuration Guide

All other documents associated with this project are the exclusive work of the author.

DISCLAIMER

The Safeguard Compliance Assessment does not require electronic Protected Health Information as part of its intended operation nor is it capable of accepting ePHI.

The SCA is not a substitute or replacement for AICPA SOC-2, Type II or HITRUST audits or certification, or any other HIPAA-related compliance or certification framework.

While it shares certain fundamental elements with both SOC-2 and HITRUST (i.e., the HIPAA Security Rule, NIST documentation and guidance) it differs in scope (limited to Security Rule Safeguards), scoring model, validation, reporting modes, integration of NIST SP.800-53r5 Control Catalog and other elements, and is based strictly on HHS proposed changes to the Security Rule.

This assessment is provided for informational purposes only and does not constitute legal advice. The questions and scoring are based on HHS RIN 0945-AA22 Notice of Proposed Rulemaking (NPRM).

Question text has been modified for readability. Please refer to HHS RIN 0945-AA22 NPRM for official regulatory text and requirements.

REFERENCES

Department of Health and Human Services-Office for Civil Rights. (2024, December 27). *HHS Office for Civil Rights Proposes Measures to Strengthen Cybersecurity in Health Care Under HIPAA*. [Press Release]. <https://www.hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm/factsheet/index.html>

Executive Order 12866: 3 C.F.R. 638 (1994). govinfo.gov

Executive Order 13132: 3 C.F.R. 206 (2000). govinfo.gov

Executive Order No. 14110, 88 Fed. Reg. 75191 (Oct. 30, 2023). federalregister.gov

Henry, K. (2024, April 22). *ePHI Explained: What Counts—and What Does Not—Under HIPAA*. <https://www.accountablehq.com/post/ephi-explained-what-counts-and-what-does-not-under-hipaa>

Jackson, P. (1998). *Introduction To Expert Systems* (3rd ed.). Addison-Wesley.

Legal Information Institute. (n.d.). *45 CFR § 164.308 — Administrative safeguards*. Cornell Law School. <https://www.law.cornell.edu/cfr/text/45/164.308>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>

U.S. Department of Health and Human Services. (2013). 45 C.F.R. Part 164, Subpart C — Security Standards for the Protection of Electronic Protected Health Information. Electronic Code of Federal Regulations. <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C>

U.S. Department of Health and Human Services. (2025). *HIPAA Security Rule to Strengthen the Cybersecurity of Electronic Protected Health Information* [Proposed rule]. *Federal Register*, 90(3), 898–1022. <https://www.federalregister.gov/documents/2025/01/06/2024-30983/>

U.S. Department of Health and Human Services, Office for Civil Rights, & Office of the National Coordinator for Health Information Technology. (2023, October 13). *HHS OCR/ONC announce an updated version of its HIPAA Security Risk Assessment Tool*. HealthIT.gov. <https://healthit.gov/news/hhs-ocr-onc-announce-updated-version-its-hipaa-security-risk-assessment-tool/>